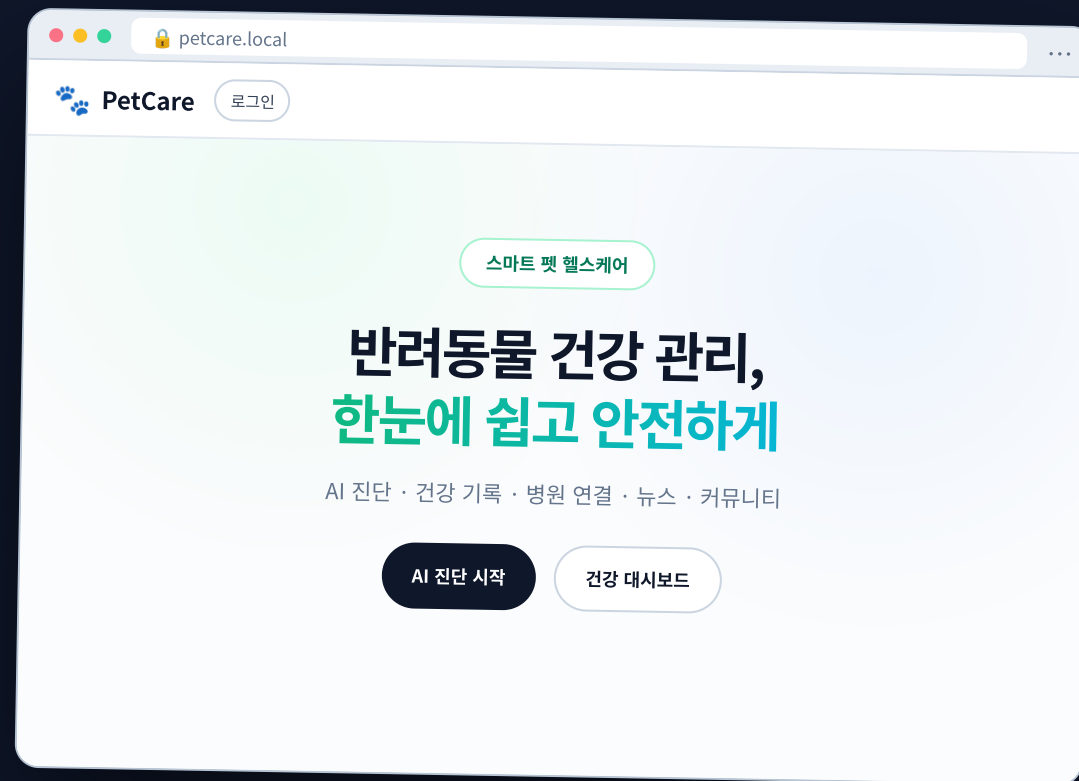


PRESENTER JIHO · TEAM PROJECT · 2026

사용자 화면에서 프론트·백엔드·DB, 그리고 보안까지.

팀원 세 명의 구현을 화면 → 코드 → 데이터 → 보안 흐름으로 연결합니다.

태준 · 진한 · 지호



PetCare가 해결하려는 사용자 문제

건강 이상을 기록하고 판단한 뒤, 병원·경과 관리·정보 공유까지 끊기지 않게 연결하는 것이 목표입니다.

01

응급 판단의 어려움

야간에 증상이 생겨도 지금 병원에 가야 하는지 판단하기 어렵습니다.

02

기록의 분산

체온·체중·증상 사진이 흩어져 이전 상태와 비교하기 어렵습니다.

03

정보 연결 부족

진단 결과가 병원 찾기, 뉴스, 커뮤니티로 자연스럽게 이어지지 않습니다.

PetCare의 답

PHR 건강 기록 → AI 진단 → Safety Triage → 병원/타임라인 → 커뮤니티 공유

세 명이 사용자 기능을 나눠 풀스택으로 구현했습니다

각 담당자는 자신의 화면과 API를 함께 책임지고, 공용 App·Security·DB 경계에서 서로 연결했습니다.

**태준**

AUTH · PHR · DAILY CARE

- ✓ 회원가입 · 로그인 · OAuth · 마이페이지
- ✓ 반려동물 등록 · 수정 · 선택
- ✓ 건강 대시보드 · 챗봇 · 진료 계산

**진한**

AI DIAGNOSIS · TIMELINE

- ✓ 환부 이미지 · 증상 입력
- ✓ 파일 검증 · FastAPI · RAG 진단
- ✓ Safety Triage · Before/After 타임라인

**지호**

NEWS · HOSPITAL · COMMUNITY

- ✓ 뉴스 검색 · 6시간 캐시
- ✓ 병원 지도 · 거리 · 24시 후보 · 북마크
- ✓ 커뮤니티 CRUD · 리포트 첨부 · 댓글 · 좋아요

공용 연결 App.jsx 화면 전환 · Spring Security/JWT · 관계형 DB · 외부 API · PR 리뷰

한 번의 진단이 후속 행동까지 이어지는 흐름

화면은 탭으로 분리되어 있지만 선택된 반려동물과 진단 결과 상태를 공유해 다음 기능으로 이어집니다.

STEP 01

반려동물 등록

프로필과 기본 정보를 선택합니다.

STEP 02

건강 기록

체온·체중·일과를 확인합니다.

STEP 03

AI 진단

환부 이미지와 증상을 입력합니다.

STEP 04

행동 선택

병원·타임라인·커뮤니티로 이동합니다.

App.jsx의 `activeTab`, `selectedPet`, `latestDiagnosis` 가 화면 간 연결 상태를 관리합니다.

React 화면부터 DB·외부 API까지 연결한 구조

React SPA가 Spring Boot API를 호출하고, 도메인 서비스가 DB·Naver·Gemini/FastAPI 경계를 분리합니다.

React 19 + Vite

Navbar · 화면 컴포넌트 · API 모듈

REST / JWT / Cookie

Spring Boot + Spring Security + MyBatis

Auth · Pet · Diagnosis · Timeline · Hospital · News · Community

DB

사용자 · 펫 · 진단 · 게시물 · 북마크

FastAPI / Gemini

이미지 분석 · RAG · 챗봇

Naver APIs

뉴스 검색 · 지역 검색

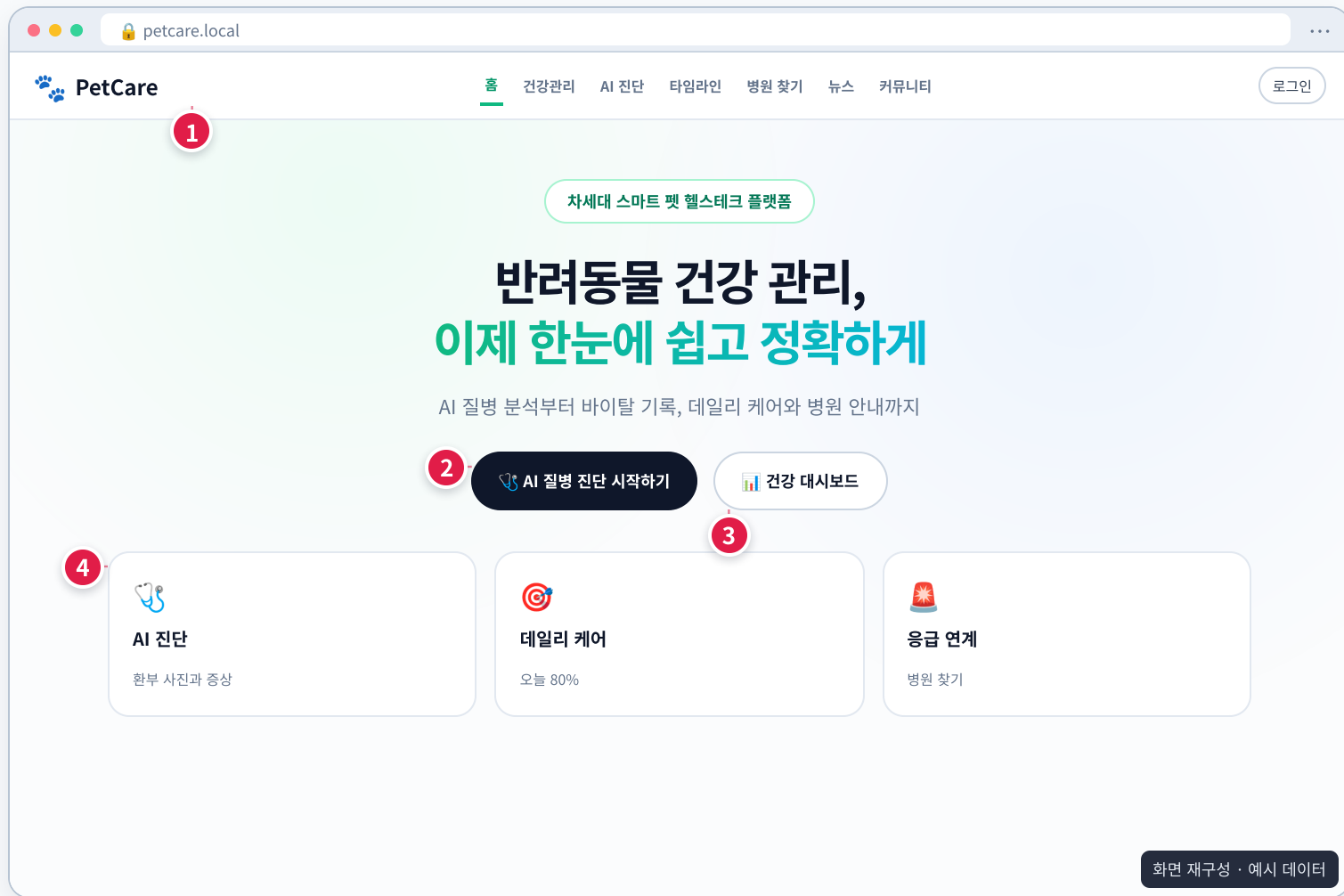
Leaflet / OSM

지도 시각화

SecurityConfig · 소유권 검사 · 입력 검증 · Rate Limit · 출력 Escape

홈에서 핵심 기능으로 바로 이동합니다

첫 화면에서 핵심 행동 두 개를 먼저 제시하고, 아래 카드로 나머지 서비스의 목적을 미리 보여줍니다.



구현 담당: 팀 공통

화면에서 코드까지

1 상단 내비게이션

탭을 선택하면 `App.jsx`의 `activeTab` 상태가 바뀌고 해당 화면이 표시됩니다.

2 AI 진단 시작 버튼

홈에서 진단 입력 화면으로 연결해 사용자가 사진·증상을 입력할 수 있게 합니다.

3 건강 대시보드 버튼

선택된 반려동물 상태를 유지한 채 건강 기록과 일과 관리 화면으로 이동합니다.

4 서비스 미리보기

`HeroSection.jsx`가 소개 카드를 만들고, `App.jsx`가 화면 전환을 연결합니다.

로그인에서 개인 데이터의 계정 경계를 세웠습니다

자체 로그인과 OAuth를 같은 화면에 제공하지만, 서버에서는 사용자 식별과 토큰 흐름을 분리합니다.

The screenshot shows a web browser at `petcare.local/login`. The page has a dark blue sidebar on the left with a paw print logo and text: **반려동물의 건강을 한곳에서 관리하세요** (Manage your pet's health in one place). Below it, smaller text says: 계정마다 자신의 반려동물과 기록만 확인합니다. (Check only your own pets and records for each account).

The main content area is white and contains a login form. The form has two tabs: **로그인** (Login) and **회원가입** (Sign Up). The **로그인** tab is selected. The form fields are: **이메일** (Email) with the value `demo@petcare.com`, and **비밀번호** (Password) with masked dots. Below the fields are three buttons: a dark blue **로그인** button, a yellow **카카오로 계속하기** (Continue with Kakao) button, and a green **네이버로 계속하기** (Continue with Naver) button. At the bottom of the form, there is a link: [비밀번호 찾기 · 계정 만들기](#) (Forgot password · Create account).

Numbered annotations (1-4) are placed on the page:
1. Points to the **로그인** tab.
2. Points to the **로그인** button.
3. Points to the **네이버로 계속하기** button.
4. Points to the sidebar header area.

At the bottom right of the page, there is a dark blue button: **화면 재구성 · 예시 데이터** (Reset layout · Sample data).

구현 담당: 태준

화면에서 코드까지

1 로그인·회원가입 선택

자체 계정 생성과 로그인을 한 화면에서 선택하고, 인증 API로 연결합니다.

2 이메일·비밀번호 인증

로그인 요청은 Auth Controller와 Spring Security를 거쳐 토큰 발급 흐름으로 연결됩니다.

3 소셜 로그인 교환

카카오·네이버 OAuth 결과는 URL 토큰 대신 일회용 코드로 교환합니다. 상세 정책은 본문 23장입니다.

4 개인 데이터의 계정 경계

Refresh Token은 `HttpOnly` 쿠키로 관리하고, 개인 데이터는 인증·소유권 검사를 거칩니다.

선택된 반려동물을 모든 맞춤 기능의 기준으로

여러 마리를 등록하되 App에서 한 마리를 선택하고, 진단·대시보드·챗봇이 같은 선택 상태를 사용합니다.

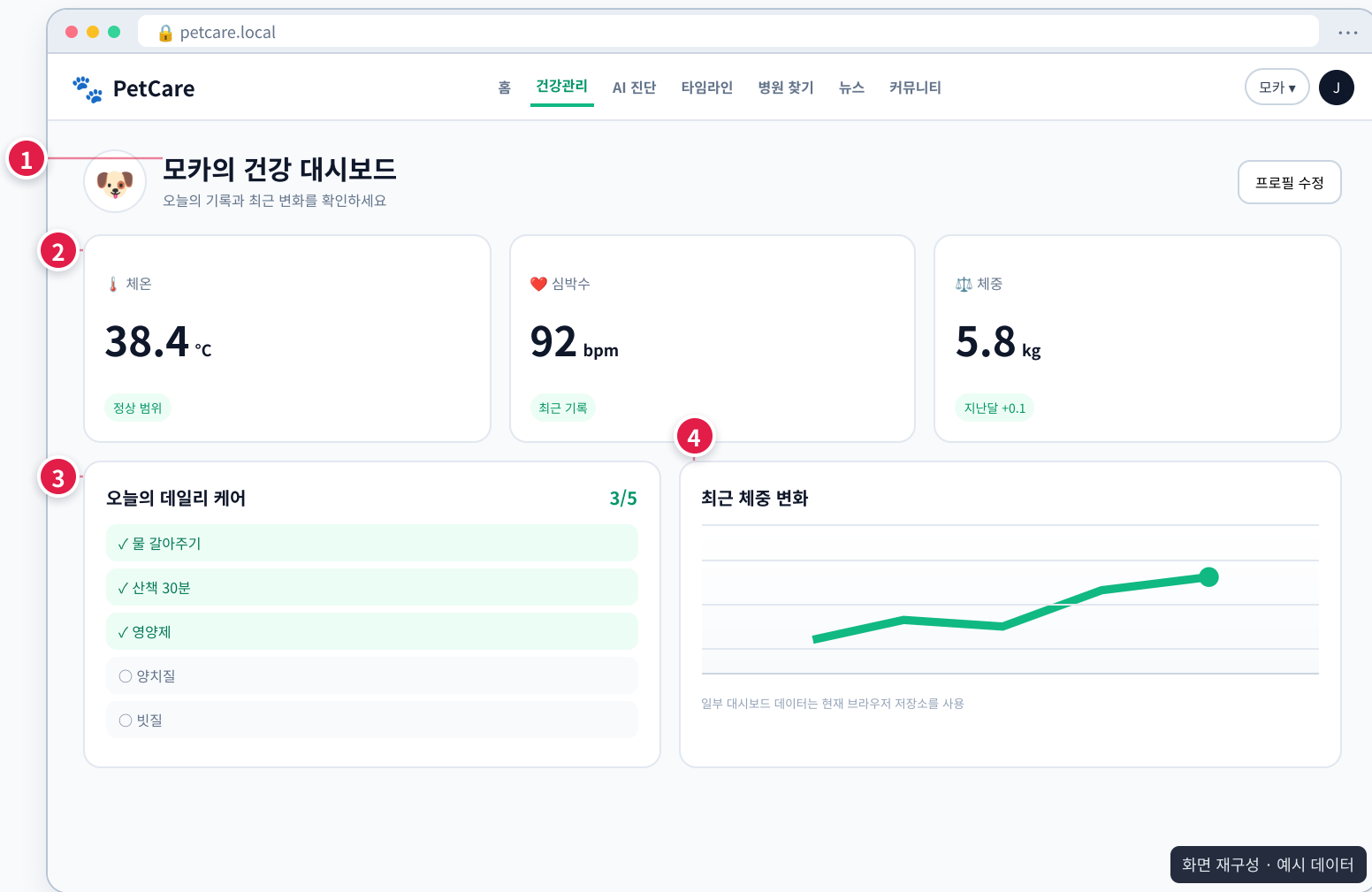
구현 담당: 태준

화면에서 코드까지

- 1 현재 반려동물 선택**
selectedPet 상태를 공유해 건강관리·챗봇·AI 진단이 같은 반려동물을 참고합니다.
- 2 새 반려동물 추가**
등록 모달에서 입력을 받은 뒤 서버의 반려동물 생성 API와 연결합니다.
- 3 프로필 입력·수정**
이름·축종·품종·체중 등 프로필을 입력하고 기존 정보는 수정 모달에서 변경합니다.
- 4 저장 요청의 소유권**
요청 본문의 userId만 믿지 않고, 서버가 현재 사용자와 반려동물의 소유 관계를 확인합니다.

프로필·바이탈·일과 기록을 한 화면에

사용자가 오늘 상태를 빠르게 확인하고, 선택된 펫의 정보를 다른 맞춤 기능으로 넘길 수 있게 구성했습니다.



구현 담당: 태준

화면에서 코드까지

1 선택된 반려동물

현재 프로필을 상단에 표시해 어느 반려동물의 기록을 보고 있는지 구분합니다.

2 바이탈 카드

체온·심박수·체중을 카드로 모아 오늘 상태와 최근 기록을 함께 확인하게 합니다.

3 오늘의 케어 체크

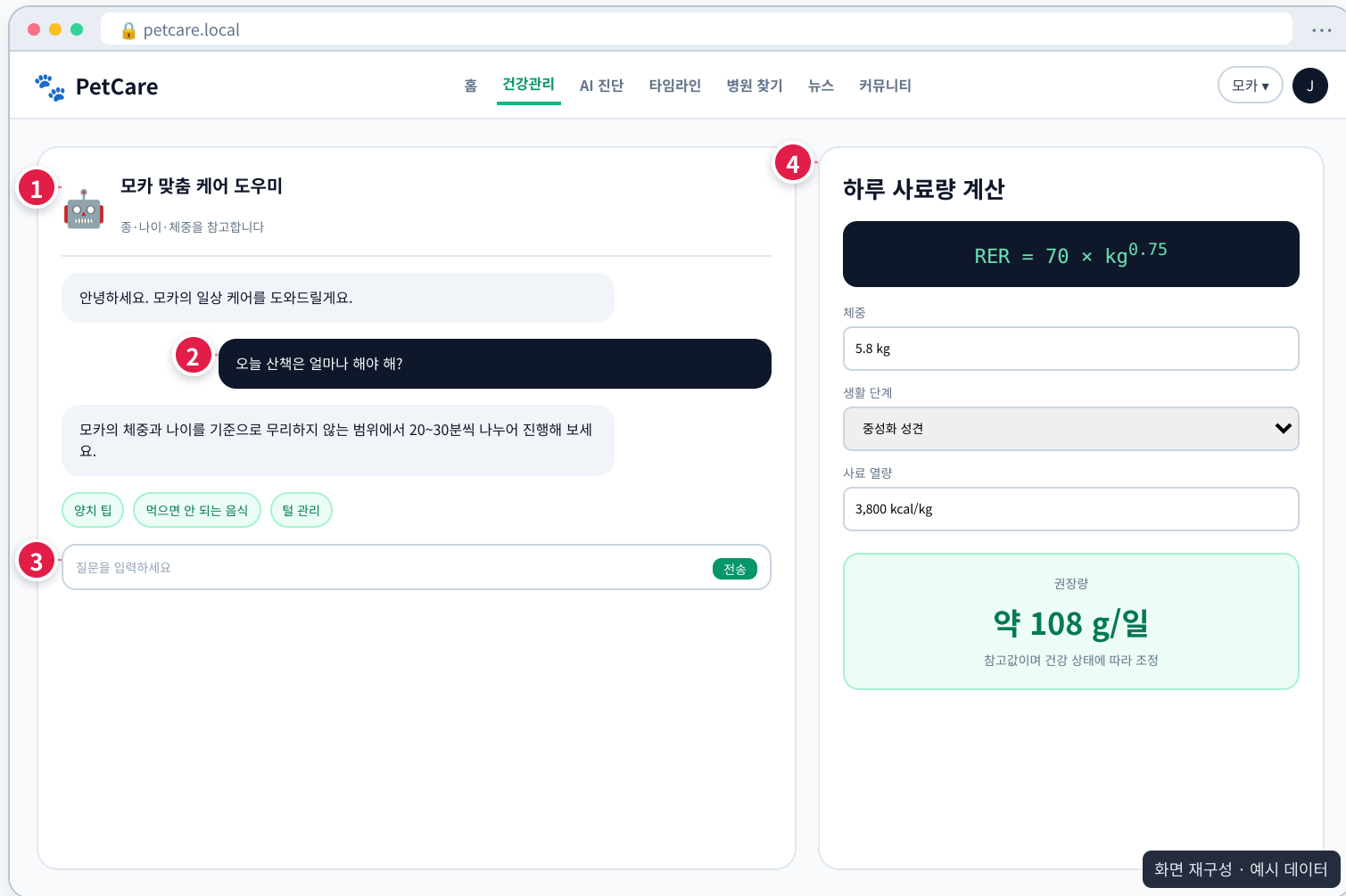
`PetHealthDashboard.jsx` 에서 카드·체크리스트·그래프를 조합해 오늘 상태를 보여줍니다.

4 추이와 저장 범위

그래프로 변화를 보여줍니다. 원본 보고서상 일부 바이탈·리마인더는 브라우저 저장소 기반이며 서버 저장 전환이 남아 있습니다.

펫 컨텍스트를 챗봇에, 영양 계산은 별도 UI로

챗봇은 생활 관리 중심으로 제한하고, 사료 계산은 RER/MER 공식을 별도 계산 UI로 제공합니다.



구현 담당: 태준

화면에서 코드까지

- 반려동물 컨텍스트**
선택된 반려동물 정보를 생활 케어 질문과 함께 전달해 답변의 참고 맥락으로 사용합니다.
- 대화 상태 관리**
사용자 메시지와 답변을 구분하고, 요청 중 로딩과 실패 시 오류 상태를 관리합니다.
- 인증된 채팅 API**
`/api/v1/chat/**`를 인증 필수로 전환했습니다. 익명 요청이 서버의 Gemini 호출을 이용하던 경로를 제한합니다.
- 사료량 계산 UI**
체중·생활 단계·사료 열량을 입력해 RER/MER 기반 참고 급여량을 계산합니다. 건강 상태에 따른 조정이 필요합니다.

사진·반려동물·증상을 구조화해 진단을 요청합니다

프론트에서 입력 단계를 명확히 나누고, 서버는 인증·파일·입력값을 다시 검증합니다.

The screenshot shows a web browser at petcare.local displaying the 'AI 반려동물 질병 진단 스튜디오' (AI Pet Disease Diagnosis Studio). The interface is divided into two main sections. On the left, a large dashed box labeled '1' contains a green plus icon and the text '환부 사진을 끌어놓거나 선택' (Drag and drop or select the patient's photo), with subtext 'JPEG · PNG · WebP / 파일과 크기 검사' (File and size check) and a '사진 선택' (Select photo) button. On the right, a form labeled '2' contains a '반려동물' (Pet) dropdown menu with '모카 · 강아지' (Moka · Dog) selected. Below it, a '환부 부위' (Patient's part) section has radio buttons for '눈' (Eye), '귀' (Ear), '피부' (Skin), '구강' (Mouth), and '관절' (Joint), with '눈' selected. A '관찰 증상' (Observed symptoms) section has buttons for '충혈' (Redness), '눈곱' (Discharge), '부종' (Swelling), and '가려움' (Itching), with '충혈' and '눈곱' selected. A '추가 소견' (Additional findings) text area contains the text '오늘 아침부터 한쪽 눈을 자주 비웁니다.' (I have been wiping one eye frequently since this morning). A large green button labeled '4' with the text 'AI 분석 요청' (Request AI analysis) is at the bottom. A footer bar contains the text '화면 재구성 · 예시 데이터' (Screen restructuring · Example data).

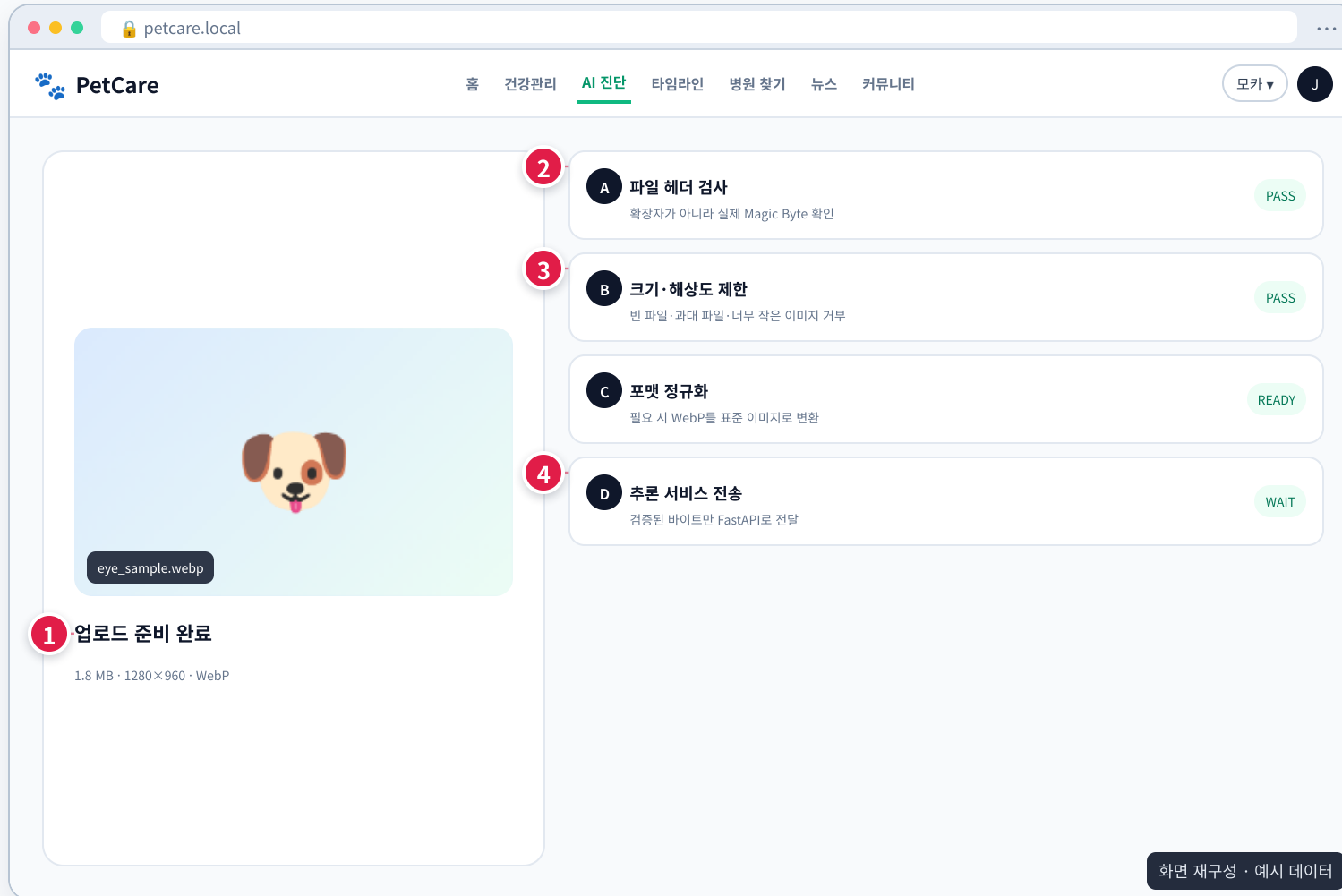
구현 담당: 진한

화면에서 코드까지

- 1 환부 이미지 업로드**
사진을 드래그하거나 선택해 진단 요청에 넣습니다.
서버에서도 파일을 다시 검사합니다.
- 2 반려동물 선택**
진단의 대상 프로필을 고릅니다. 서버는 사용자와
반려동물 소유권을 확인합니다.
- 3 부위·증상·추가 소견**
이미지 외의 관찰 정보를 구조화해 API 요청에 함께
전달합니다.
- 4 AI 분석 요청**
검증을 통과한 입력만 추론 서비스로 넘기고 결과를
후속 화면에 연결합니다.

실제 이미지 바이트를 검증한 뒤 추론으로 보냅니다

진단 품질과 보안을 동시에 지키기 위해 업로드와 AI 호출 사이에 검증 계층을 두었습니다.



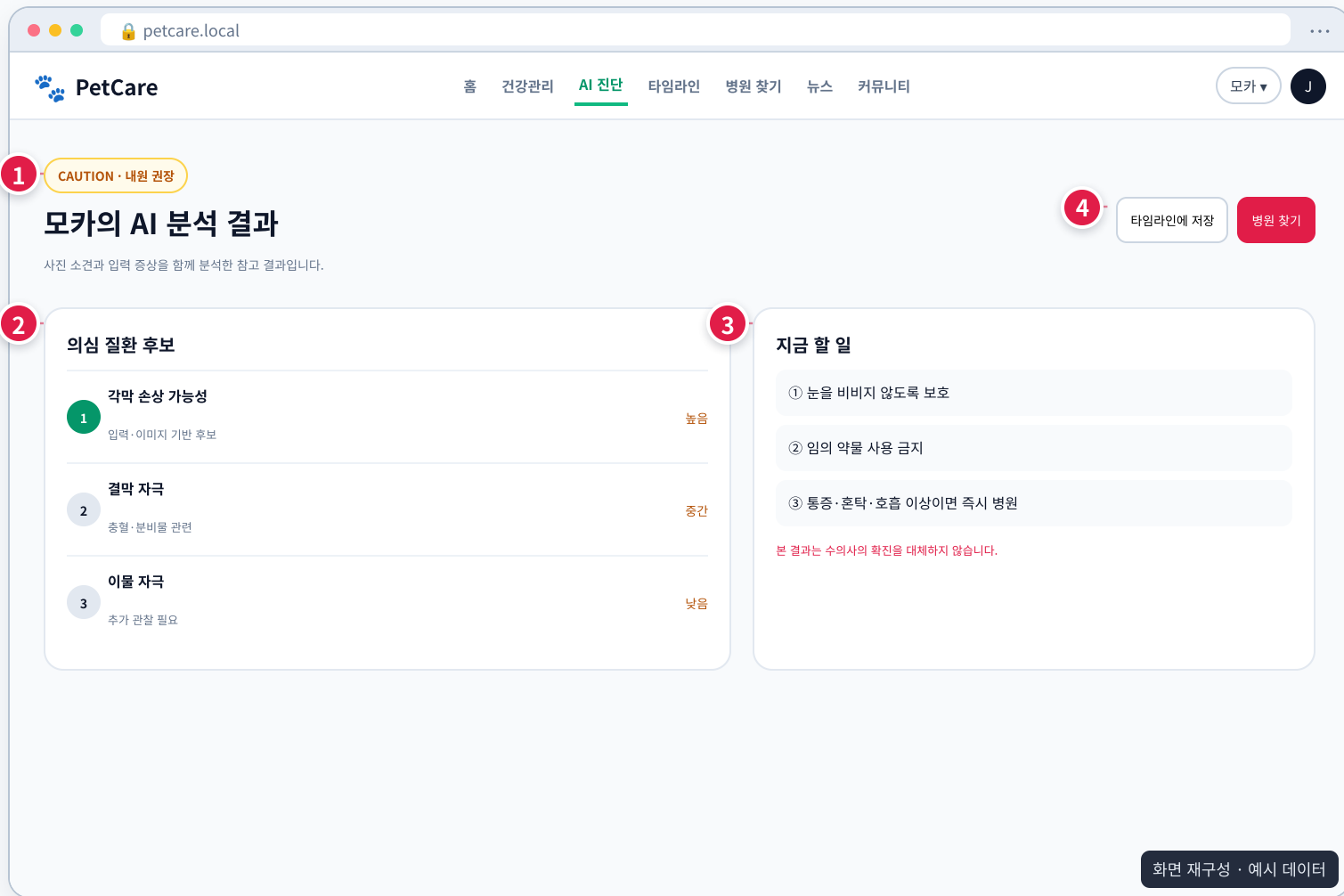
구현 담당: 진한

화면에서 코드까지

- 1 원본 파일 확인**
파일명·미리보기·해상도를 보여주고, 잘못 올린 이미지는 교체하게 합니다.
- 2 실제 파일 헤더**
확장자만 믿지 않고 실제 Magic Byte와 디코딩 가능 여부를 검사합니다.
- 3 크기·해상도 제한**
빈 파일·과대 파일·너무 작은 이미지가 추론 호출로 넘어가지 않도록 검사합니다.
- 4 정규화 후 추론 전송**
검증된 바이트만 필요한 포맷으로 정규화해 FastAPI 추론 서비스로 전달합니다.

진단 후보를 위험 단계와 다음 행동으로 연결합니다

결과는 참고 후보로 표현하고, 응급·주의·관찰 단계에 따라 병원 또는 경과 관리 동선을 다르게 제공합니다.



구현 담당: 진한

화면에서 코드까지

1 위험 단계 표시

응급·주의·관찰 단계를 구분해 보호자가 결과의 우선순위를 이해하도록 합니다.

2 의심 질환 후보

분석 결과는 수의사의 확진이 아닌 참고 후보로 표시합니다.

3 다음 행동 안내

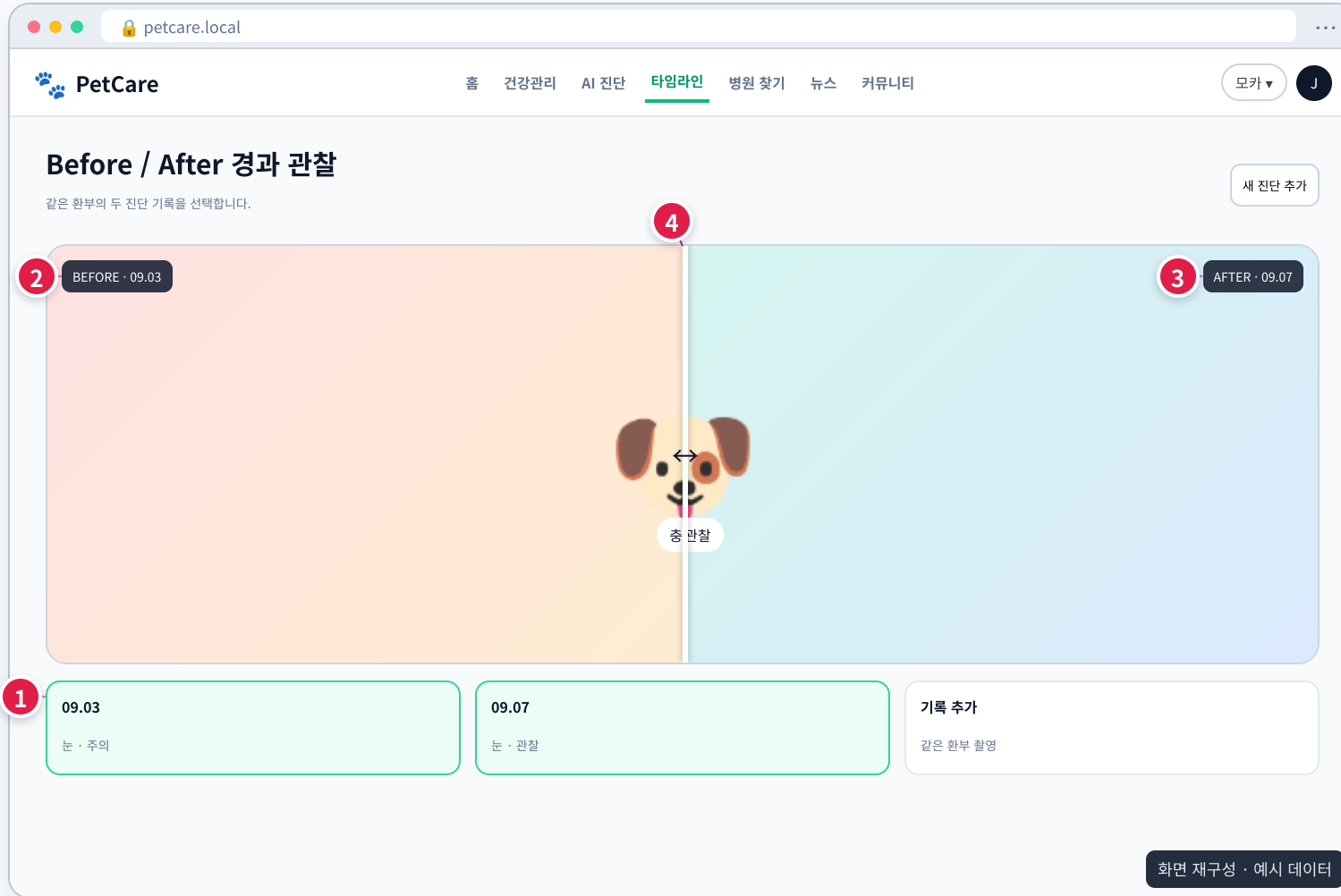
질환명 목록만 보여주지 않고 보호자가 다음에 할 행동을 함께 제공합니다.

4 병원·타임라인 연결

결과를 확인한 뒤 병원을 찾거나 진단 기록을 타임라인으로 이어서 볼 수 있습니다.

같은 반려동물의 두 진단 기록을 비교합니다

정적인 예시 이미지가 아니라 저장된 진단 기록을 기준으로 하며, 소유권이 확인된 기록만 조회합니다.



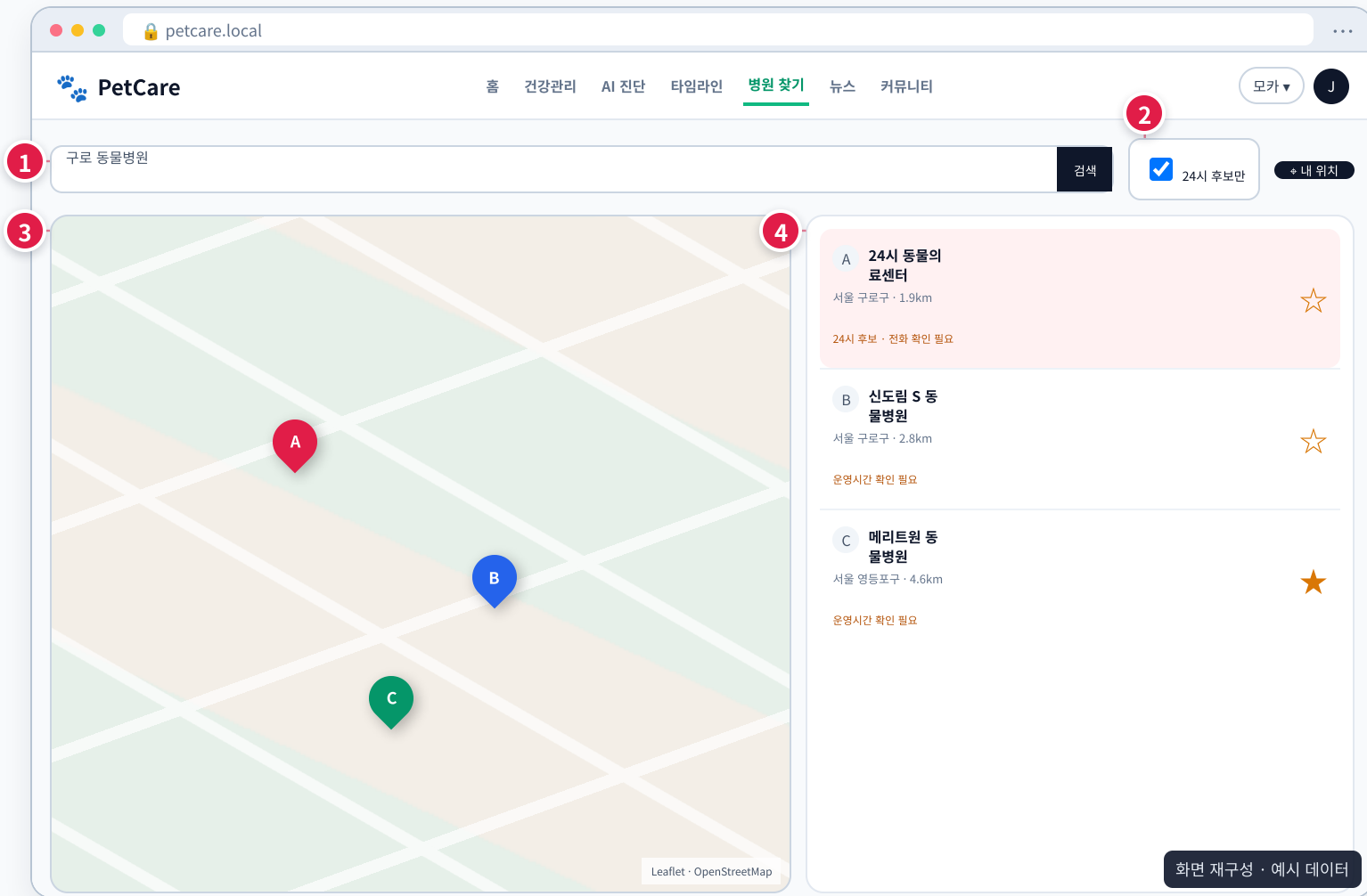
구현 담당: 진한

화면에서 코드까지

- 1 기록 두 건 선택**
같은 반려동물의 이전·이후 진단 기록을 골라 비교 대상으로 설정합니다.
- 2 이전 진단 이미지**
저장된 이전 기록의 환부 이미지를 비교 화면에 표시합니다.
- 3 이후 진단 이미지**
새 기록을 함께 표시합니다. 서버는 사용자 소유의 반려동물과 기록만 조회합니다.
- 4 비교 슬라이더**
슬라이더 위치와 이미지 겹침 폭을 화면 상태로 관리해 전후 사진을 비교합니다.

병원 검색 데이터와 지도 표시를 분리했습니다

병원 상호·주소·좌표는 네이버 지역검색에서 받고, 지도는 Leaflet·OpenStreetMap으로 시각화합니다.



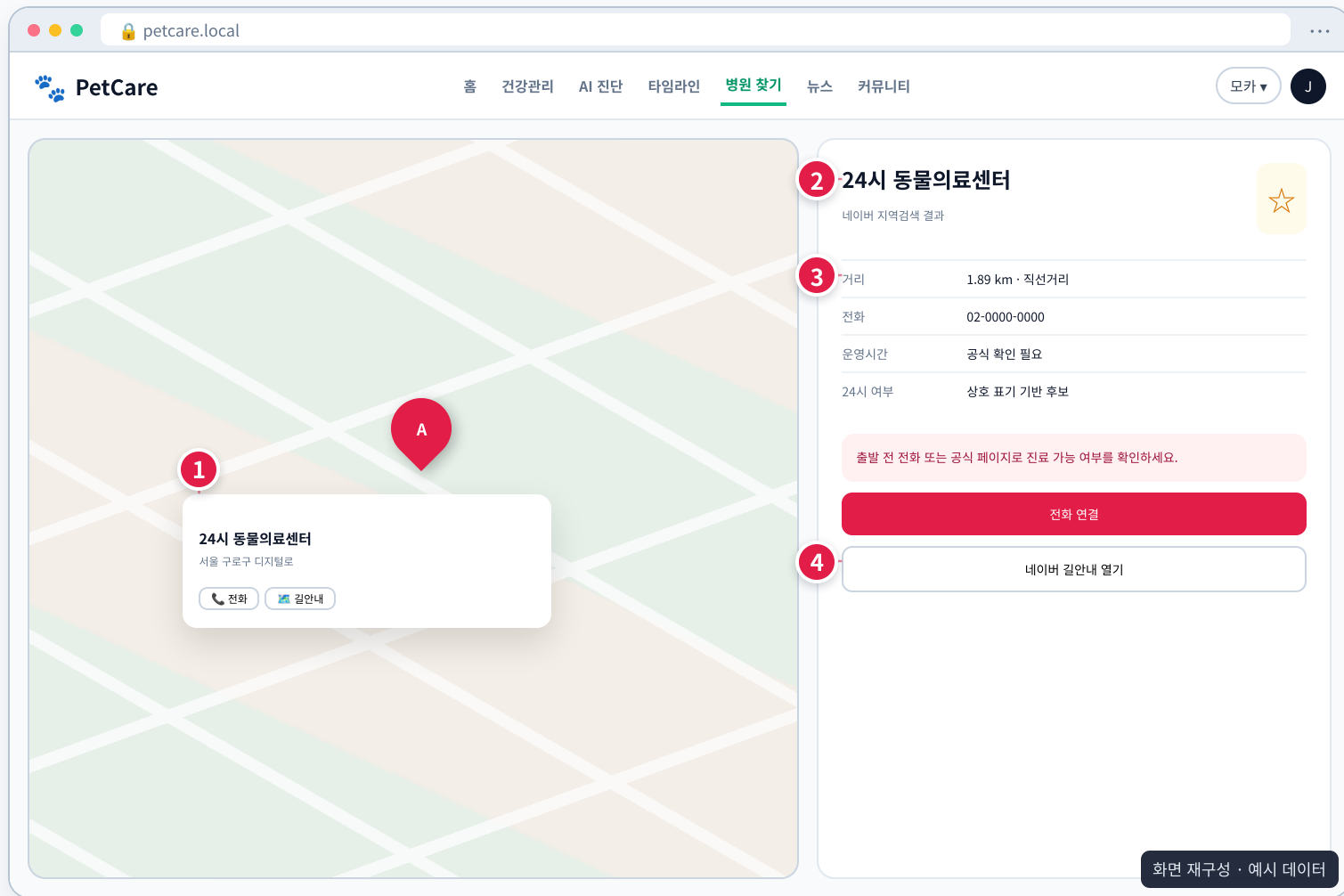
구현 담당: 지호

화면에서 코드까지

- 지역 검색·내 위치**
지역명 또는 사용자 좌표를 기준으로 네이버 지역검색 API를 조회합니다.
- 24시 후보 필터**
상호의 24시·응급 표기 기반 후보를 분류합니다. 현재 영업을 보장하는 정보는 아닙니다.
- 지도 표시 계층**
병원 데이터는 네이버에서 받고, 지도 표시는 Leaflet·OpenStreetMap으로 분리했습니다.
- 거리순 목록**
서버가 사용자·병원 좌표로 Haversine 거리를 계산해 정렬합니다. 주행거리·이동시간은 아닙니다.

병원 운영시간은 확인된 수준까지만 표시합니다

지도 팝업·목록·상세 패널 모두 같은 안전한 외부 링크 규칙과 안내 문구를 사용합니다.



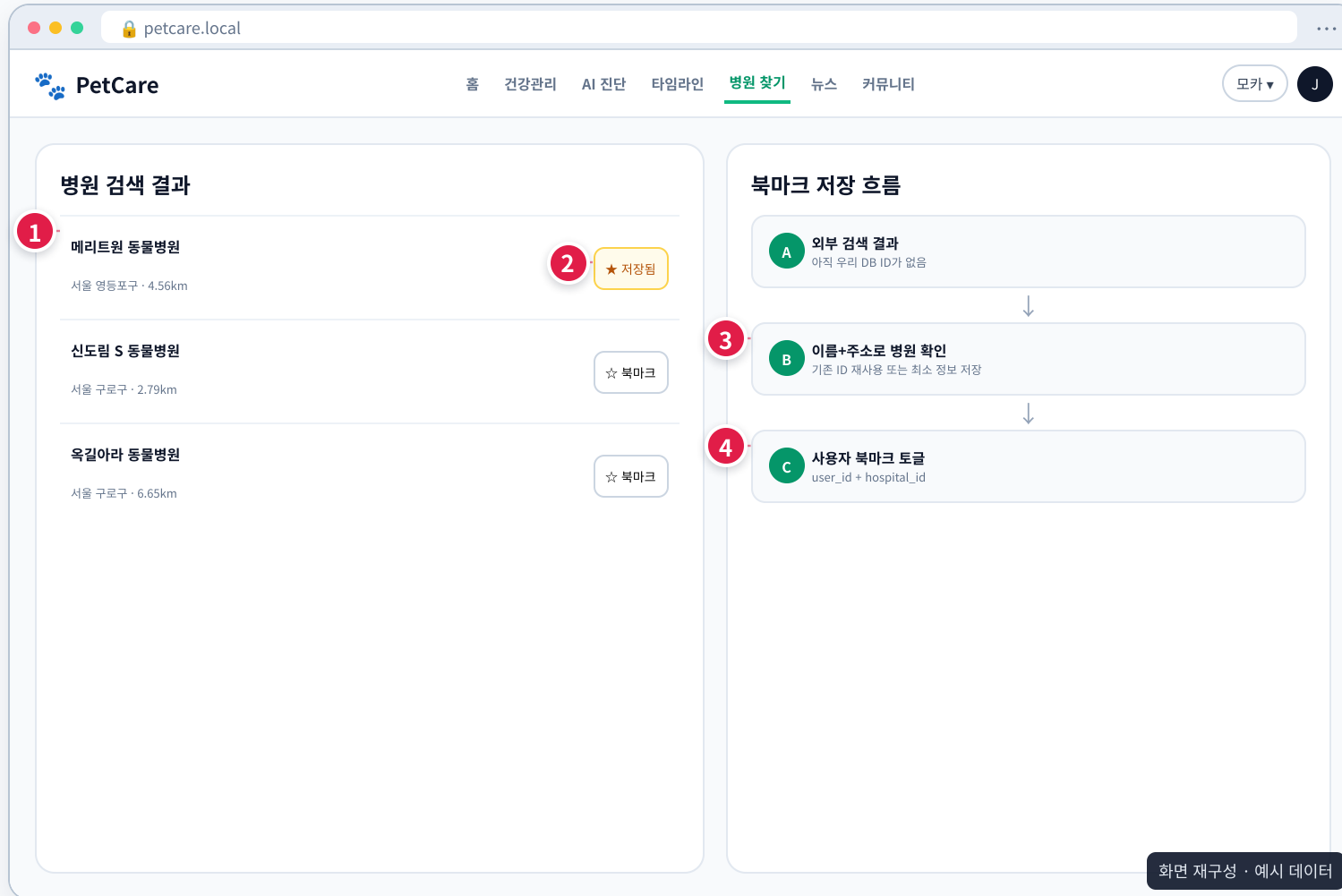
구현 담당: 지호

화면에서 코드까지

- 1 지도 팝업 출력 보호**
외부 병원명·주소에 `escapeHtml()` 을 적용한 뒤 HTML 팝업에 표시합니다.
- 2 병원 정보의 출처**
상호·주소·좌표 등 네이버 지역검색이 제공한 값을 화면에 연결합니다.
- 3 운영시간의 확인 수준**
모르는 운영시간을 임의로 채우지 않고, 24시 표기는 상호 기반 후보라고 안내합니다.
- 4 전화·길안내 연결**
방문 전 전화 확인을 안내하고, 지도 URL은 `https://map.naver.com` 허용 목적지인지 검증합니다.

외부 병원 결과를 내부 ID와 사용자 북마크로 연결

병원을 먼저 식별·저장한 뒤 사용자와 연결하고, 화면은 Set과 요청 잠금으로 중복 클릭을 줄입니다.



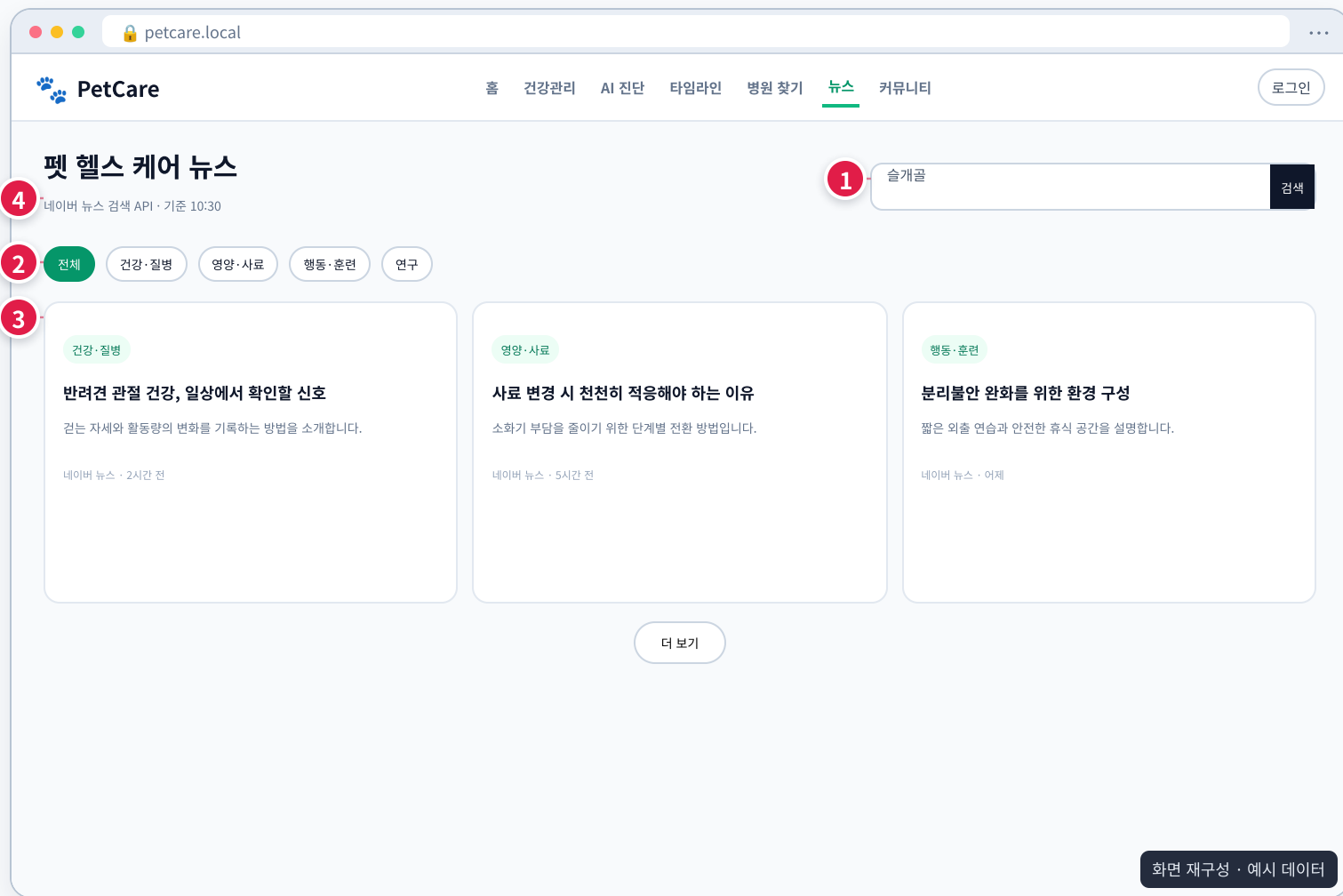
구현 담당: 지호

화면에서 코드까지

- 외부 검색 결과**
검색 결과에는 우리 서비스의 내부 병원 ID가 없으므로 먼저 병원을 식별해야 합니다.
- 북마크 토글**
별 버튼으로 저장·해제합니다. 화면의 Set·요청 잠금은 중복 클릭을 줄이는 역할입니다.
- 내부 병원 ID 확보**
이름+주소로 기존 병원을 찾고, 없으면 필요한 정보를 저장해 실제 ID를 사용합니다.
- DB 중복 방지 과제**
`hospital_bookmarks` 의 `(user_id, hospital_id)` 유니크 제약은 후속 과제입니다.

기본 뉴스와 사용자 검색을 구분했습니다

검색·카테고리·더보기를 한 화면에 제공하면서 기사 링크와 캐시 기준 시각을 함께 표시합니다.



구현 담당: 지호

화면에서 코드까지

1 검색 요청 구분

입력 중인 값과 실제 서버에 보낸 검색어를 분리해 타이핑마다 요청하지 않게 했습니다.

2 카테고리 선택

전체·건강·영양·행동·연구 등 분류를 한 화면에서 선택합니다.

3 기사 카드·외부 링크

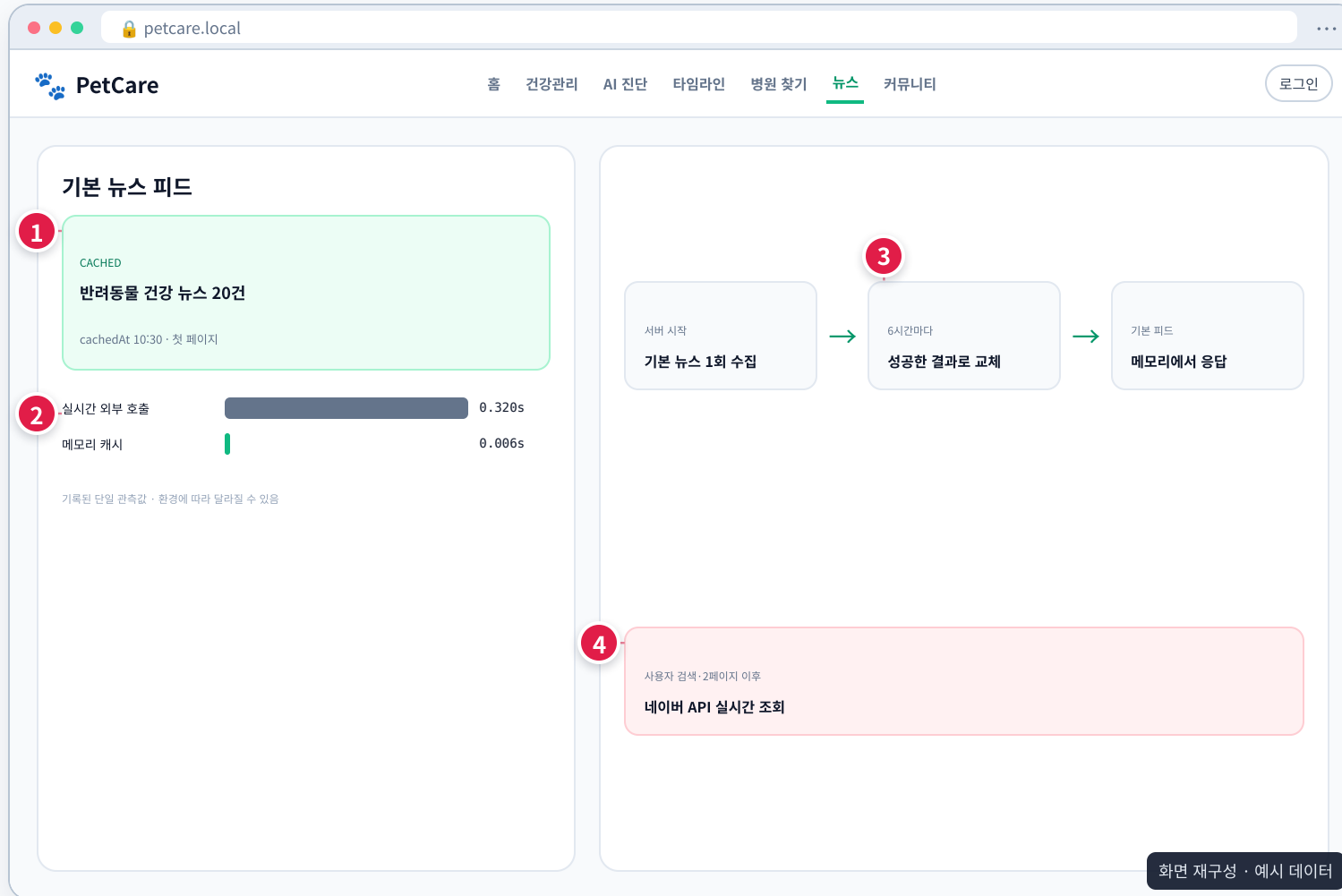
뉴스 URL은 http/https만 허용하고 `rel="noopener noreferrer"`를 적용합니다.

4 조회 기준 시각

캐시 기준 시각을 함께 보여줍니다. 사용자 검색·다음 페이지는 외부 API 조회입니다.

기본 피드는 6시간 캐시, 사용자 검색은 실시간 조회

기본 첫 페이지와 사용자 검색을 분리하고, 빈 응답이나 예외가 발생하면 기존 정상 캐시를 유지합니다.



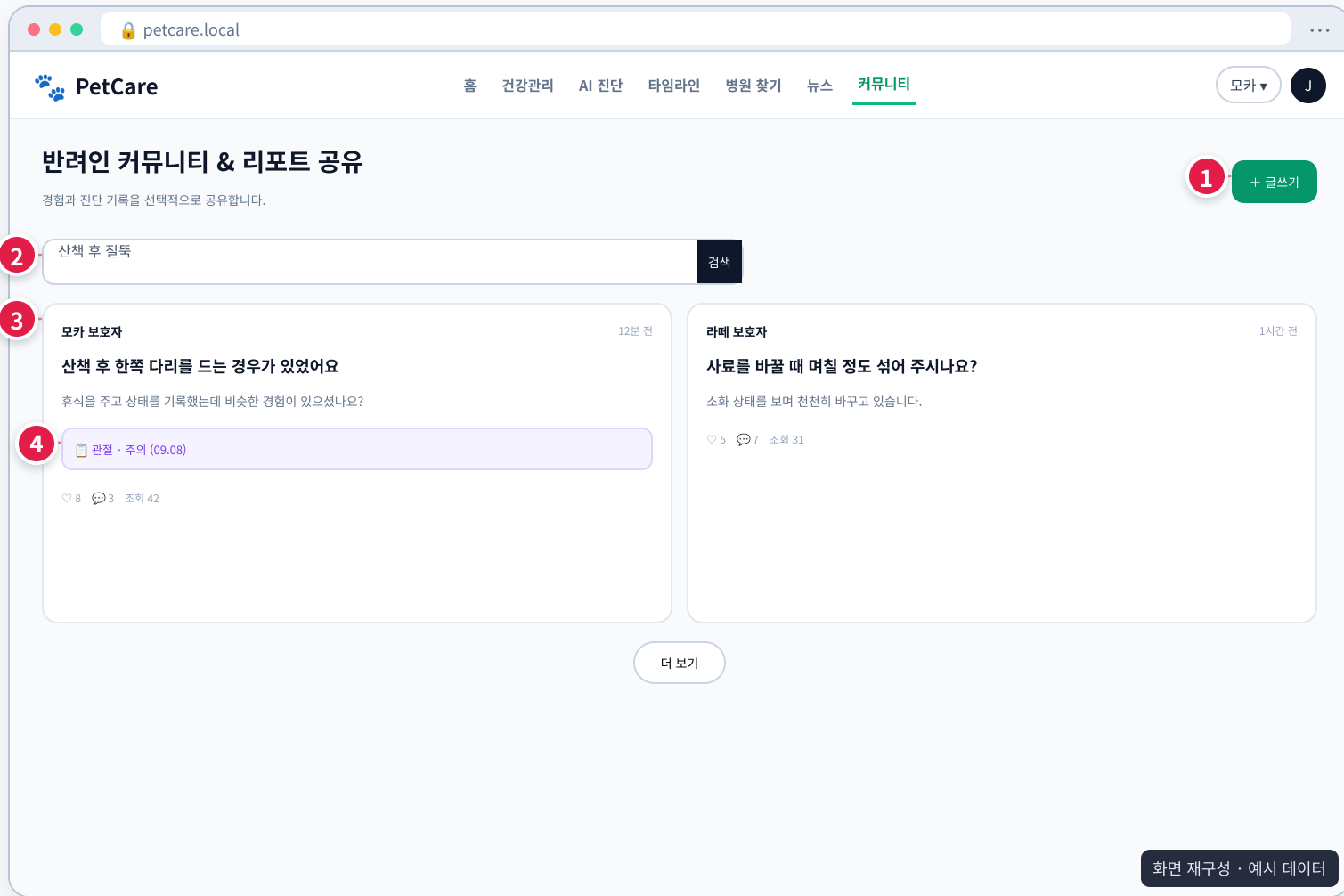
구현 담당: 지호

화면에서 코드까지

- 1 기본 첫 페이지 캐시**
기본 피드는 메모리에서 응답하고, 빈 결과·실패 시 이전 정상 캐시를 유지합니다.
- 2 관측된 응답 시간**
원본 작업기록은 외부 호출 0.320초, 캐시 0.006초입니다. 단일 관측이며 성능 보장은 아닙니다.
- 3 수집·갱신 스케줄**
서버 기동 시 수집하고, 이후 6시간마다 성공한 기본 피드 결과로 캐시를 갱신합니다.
- 4 캐시를 쓰지 않는 요청**
사용자 검색·2페이지 이후는 네이버 API를 조회합니다. 호출량 제한은 보안 본문 24장에 정리했습니다.

일반 글과 리포트 첨부 글을 함께 보여줍니다

검색·페이징·첨부 리포트 표시를 서버 응답 기준으로 처리해 화면과 데이터 상태를 맞춥니다.



구현 담당: 지호

화면에서 코드까지

- 1 글쓰기 진입**
사용자가 새 글을 작성하고 본인 리포트를 선택적으로 첨부할 수 있게 연결합니다.
- 2 검색·페이지 조회**
검색어와 페이징 조건을 서버에 전달하고 응답 기준으로 목록을 갱신합니다.
- 3 목록 정보 조합**
게시글·작성자·댓글 수·좋아요 수·리포트 라벨을 서버 응답으로 조합합니다.
- 4 선택 첨부 유지**
첨부 리포트 관계를 `LEFT JOIN` 으로 연결해 리포트 없는 게시글도 목록에 남깁니다.

내 리포트만 선택하고, 서버가 소유권을 다시 검사

작성자는 JWT에서 결정하고, 첨부 후보 조회와 작성·수정 요청 모두에서 리포트 소유권을 확인합니다.

petcare.local

PetCare

홈 건강관리 AI 진단 타임라인 병원 찾기 뉴스 커뮤니티

모카 J

커뮤니티 글쓰기

내 진단 리포트는 선택적으로 첨부할 수 있습니다.

1 제목

산책 후 다리를 드는 증상 경험 공유

내용

오늘 산책 후 오른쪽 뒷다리를 잠깐 들었습니다. 휴식 후 좋아졌지만 비슷한 경험이 있으신가요?

2 내 AI 진단 리포트

관절 · 주의 (2026.09.08)

3

관절 · 주의

모카 · 2026.09.08 · 본인 소유 확인

4

취소 게시하기

화면 재구성 · 예시 데이터

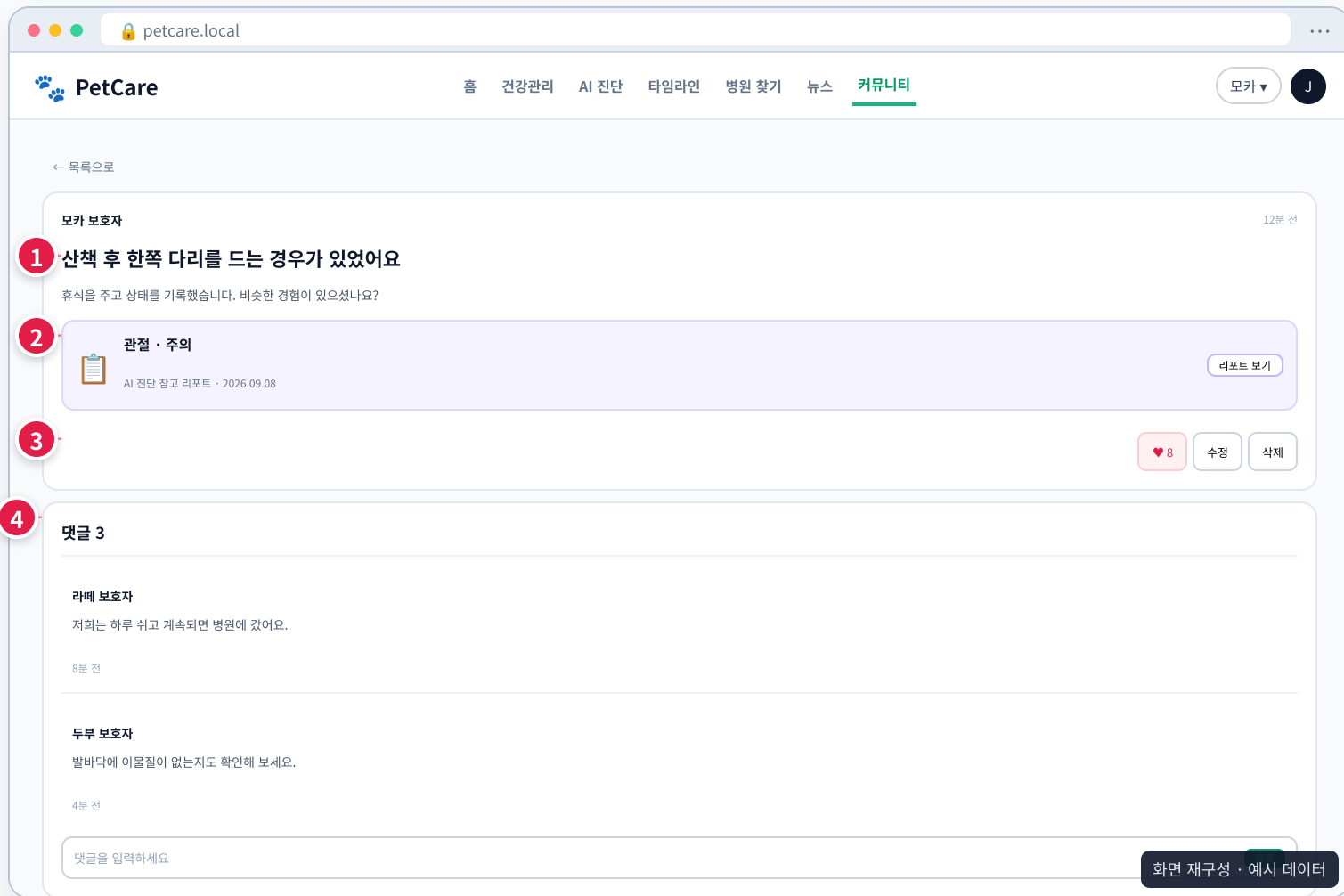
구현 담당: 지호

화면에서 코드까지

- 1 제목·본문 입력**
작성할 게시글 내용을 입력하고 서버의 작성 API로 보냅니다.
- 2 내 리포트 후보 조회**
현재 인증 사용자 기준으로 첨부 가능한 본인 리포트만 목록에 보여줍니다.
- 3 첨부 대상 재검증**
화면 후보 제한과 별개로, 서버가 작성·수정 요청에서 리포트 소유권을 다시 확인합니다.
- 4 JWT로 작성자 결정**
게시 요청의 userId가 아니라 JWT 인증 사용자 ID를 작성자로 사용합니다.

댓글·좋아요·수정·삭제마다 서버 조건을 확인합니다

화면의 버튼 노출뿐 아니라 SQL의 user_id·post_id 조건과 영향 행 수로 권한 결과를 확인합니다.



구현 담당: 지호

화면에서 코드까지

- 1 게시물 상세 조회**
서버의 게시물 응답을 기준으로 제목·본문·작성자과 연결된 정보를 표시합니다.
- 2 첨부 리포트 표시**
선택 첨부한 AI 진단 리포트를 카드로 연결합니다. 리포트 첨부 권한은 작성·수정 시 재검증합니다.
- 3 좋아요·수정·삭제**
좋아요는 서버 상태로 토글합니다. 수정·삭제는 게시물 ID와 사용자 ID를 함께 확인합니다.
- 4 댓글 관계와 소유권**
수정·삭제 시 `post_id·user_id` 조건을 함께 확인합니다. 버튼 숨김만으로 권한을 판단하지 않습니다.

기본 인증·토큰 분리로 열려 있던 경로를 보강했습니다

PR #31 · 58개 파일 +1,589 / -472 · 기존 기능을 유지하며 접근·전달 정책 보완

변경 전

`.anyRequest().permitAll()`

변경 후

`.anyRequest().authenticated()`

새 API가 규칙에서 빠져도
기본적으로 인증을 요구

01 / API ACCESS

공개 예외는 명시, 개인 조회는 먼저

북마크·내 리포트·타임라인 규칙을 넓은 공개 GET보다 먼저 배치했습니다.

`/api/v1/chat/**` 도 인증 필수

익명 사용자가 서버의 Gemini 호출을 이용하던 경로 제한

02 / TOKEN

Refresh Token의 보관과 용도를 분리

`HttpOnly` 쿠키 + `SameSite=Strict`

재발급 시 이전 토큰 무효화 · Access/Refresh 용도 구분

`Refresh Token`으로 보호 API 접근 불가

03 / OAUTH2

URL 토큰 대신 일회용 코드 교환

일회용 코드를 쿠키로 전달한 뒤

`POST /auth/oauth2/exchange` 에서 교환합니다.

리다이렉트 허용 목록 · 소셜 계정 식별자

`(provider, provider_id)` 유니크 인덱스

04 / BROWSER & DEV

H2는 OFF, CORS는 허용 도메인만

H2 콘솔 비활성화 · 외부 접속 허용도 해제

`frameOptions.sameOrigin()` 복원

CORS를 `setAllowedOrigins` 로 중앙화

`@CrossOrigin("*")` 중복 11곳 제거

인증 ≠ 소유권 로그인 여부와 별개로 Controller·SQL에서 본인 데이터인지 확인합니다.

설정 상세 → 부록 A

외부 입력·API 사용량·초기 데이터까지 통제했습니다

PR #31 · 출력 처리, 요청 제한, 입력 검증, 타임아웃과 데모 데이터 분리

병원·뉴스 검색

60회 / 분 / IP

초과하면 429 + Retry-After

외부 API 사용량

25,000회 / 일

네이버 API 한도 · PR 정리 기재값

외부 API 대기 제한

연결 5초 · 읽기 10초

응답을 무기한 기다리지 않도록 제한

01 / OUTPUT

외부 문자열도 출력 전에 검사

Leaflet 팝업의 병원명·주소에

`escapeHtml()` 적용

지도 URL: `https://map.naver.com`

허용 목적지인지 확인

뉴스 링크: `http/https` 만 허용

`rel="noopener noreferrer"`

외부 API 응답도 신뢰 경계 밖의 입력

02 / REQUEST

입력값·요청량·실패 응답을 통제

로그인·회원가입: 반복 시도 제한

병원·뉴스: IP 기준 요청 제한

병원: 위경도 범위 · 지역명 **50자**

뉴스: 검색어 **100자** · `start/display` 범위

예외 응답의 내부 정보 노출 축소

연결·읽기 타임아웃 적용

캐시와 요청 제한으로 API 한도 소모 완화

03 / DATA

데모 데이터와 실제 ID를 분리

`petcare.demo-data.enabled`

기본값 **false** · 필요할 때만 demo 실행

서버 재시작 때 초기 병원 **5건**이

다시 생성되던 문제 차단

`userId(1L)` 하드코딩 제거

`ensureUser()` / `ensurePet()`

실제 생성된 ID 사용 → 테스트 5개 회귀 해결

PR 정리의 변경·검증 기록 기준입니다. 요청 제한은 일일 한도 소모가 전혀 없다는 뜻이 아닙니다.

데이터 상세 → 부록 B

검증 결과는 시점과 실행 범위를 나눠 설명합니다

PR #31의 93/93과 후속 main의 96/97을 구분하고, 실제 HTTP 응답 기록을 함께 제시합니다.

검증 시점·대상	결과	기록의 의미
PR #31 Gradle test	93/93	수정 전 실패 5개 해결 후 통과
PR #31 compileJava	PASS	Java 컴파일 통과 기록
PR #31 npm run build	PASS	프런트 빌드 통과 기록
09.09 원격 main	96/97	후속 시점의 테스트 1개 실패 기록
프런트 테스트 / E2E	미실행	Playwright 의존성·스크립트 문제
운영 환경 E2E	미검증	OAuth·Gemini·HTTPS·Supabase

PR #31 / 비로그인 실제 요청 기록

보호 요청은 401, 공개 조회는 200

경로는 PR 정리의 축약 표기입니다.

/community/my-reports	401
/hospitals/bookmarks	401
/users/me	401
/chat/**	401
/h2-console	401

공개 조회 200 유지

커뮤니티 목록 · 뉴스(6시간 캐시)
병원 검색(24시 필터·거리순)

같은 시점의 숫자로 합치지 않습니다. 93/93은 PR #31 기록, 96/97은 원본에 기재된 2026-09-09 main 기록입니다. 이번 편집에서 앱 테스트는 재실행하지 않았습니다.

세 명의 기능은 하나의 사용자 여정 안에서 연결됩니다

등록과 건강관리부터 진단, 병원·타임라인, 커뮤니티 공유까지 화면과 권한 경계를 함께 구현했습니다.



TEAM TAKEAWAY

“화면을 만든 것”에서 끝나지 않고,
데이터 출처와 사용자 권한까지 연결했습니다.

PetCare Team · 태준 · 진한 · 지호

시연 추천 순서 홈 → 로그인/펫 선택 → 대시보드 → AI 진단 → 병원/타임라인 → 커뮤니티

Q & A

공개 예외·개인 경로 우선순위·H2·CORS 설정

질의응답용 · 핵심 설정 발췌이며 전체 SecurityConfig 소스가 아닙니다.

A1 / PUBLIC EXCEPTIONS & ORDER

예외는 명시하고, 개인 경로를 먼저 평가

공개 인증 경로 · PR 정리의 표기

POST /auth/signup · /auth/login · /auth/refresh

POST /auth/oauth2/exchange · /auth/logout

POST /auth/forgot-password

GET /auth/check-email · /auth/check-nickname

/oauth2/** · /login/** · /error

공개 일반 조회

GET /hospitals/** · /news/** · /community/**

GET /diagnosis/symptoms

```
.requestMatchers(HttpMethod.GET,
    "/api/v1/hospitals/bookmarks",
    "/api/v1/community/my-reports",
    "/api/v1/timelines/**").authenticated()
// 위 개인 경로 다음에 공개 GET 규칙 배치
// 마지막 기본값: .anyRequest().authenticated()
```

A2 / DEVELOPMENT & CORS

개발 콘솔을 닫고 브라우저 정책을 중앙화

```
spring.h2.console.enabled=false
spring.h2.console.settings.web-allow-others=false
```

/h2-console/** 공개 규칙 제거

frameOptions.sameOrigin() 으로 프레임 보호 복원

```
configuration.setAllowedOrigins(allowedOrigins);
```

setAllowedOriginPatterns(List.of("**")) 제거

컨트롤러 @CrossOrigin(origins = "**") 11곳 제거

```
app.cors.allowed-origins=
${APP_CORS_ALLOWED_ORIGINS:로컬 개발 기본값}
```

위 properties 줄바꿈은 설명용입니다. 실제 설정에는 배포 Origin 목록을 사용합니다.

데모 초기화와 Seed ID 하드코딩 문제를 함께 해결

사용자 PR 정리의 10·11번 · 가짜 초기 병원 재생성과 테스트 FK 오류는 원인이 다른 문제입니다.

B1 / DEMO INITIALIZATION

재시작마다 초기 병원 5건이 되살아났습니다

원인: `DataInitializer`의 무조건 실행

조치: 데모 초기화는 명시적으로 켜 때만 실행

```
@ConditionalOnProperty(
    name = "petcare.demo-data.enabled",
    havingValue = "true"
)
```

기본값 false

평소에는 초기화하지 않음

필요한 데모 환경에서만 활성화

```
--spring.profiles.active=demo
```

원본 기록: 초기 레코드의 검색 결과·주소 정합성 문제, 임의 평점·영업시간. 상세 사례는 대본에 보존했습니다.

B2 / TEST REGRESSION

고정 ID 대신 실제 생성된 PK를 사용했습니다

`DataInitializer.java:163` · 실패 로그 발췌

```
POSTS FOREIGN KEY(USER_ID)
REFERENCES USERS(ID) (CAST(1 AS BIGINT))
```

`countAll() == 0` 일 때만 사용자 생성

그런데 게시글은 `userId(1L)` 로 고정

공유 H2(`DB_CLOSE_DELAY=-1`)에서

다른 테스트가 먼저 데이터를 넣으면 ID 1이 없을 수 있음

```
ensureUser(email) → 실제 userId
ensurePet(userId, name) → 실제 petId
```

JwtAuthenticationFilterTest 5개 회귀 해결

PR #31 시점 전체 테스트 93/93 통과 기록

배포 설정과 다음 PR의 DB 제약을 인계합니다

완료된 보안 변경과 아직 적용하지 않은 마이그레이션을 분리해서 설명합니다.

C1 / DEPLOYMENT CHECKS

배포 환경의 쿠키·Origin을 명시적으로 설정

```
JWT_REFRESH_COOKIE_SECURE=true
APP_CORS_ALLOWED_ORIGINS=<실제 프론트 Origin>
```

로컬 HTTP에서는 Secure 기본값이 false입니다.

운영 HTTPS에서는 Secure=true 를 확인합니다.

CORS는 실제 배포 도메인 목록을 사용합니다.

운영에서는 데모 데이터 기본 OFF를 유지합니다.

후속 점검은 완료와 구분

main 실패 테스트 · 외부 키 교체·설정
OAuth·Gemini·HTTPS·Supabase E2E · CI

후속 점검 목록은 원본 HTML과 사용자 PR 정리에 있는 항목입니다. 이번 편집에서 실행한 항목이 아닙니다.

C2 / NEXT PR · NOT YET APPLIED

좋아요·북마크의 DB 유니크 제약

현재 SQL 중복 방어를 DB 제약으로 보강하는

다음 PR 제안입니다. 적용 완료로 표시하지 않습니다.

```
CREATE UNIQUE INDEX IF NOT EXISTS
  uq_post_likes_post_user
  ON post_likes(post_id, user_id);

CREATE UNIQUE INDEX IF NOT EXISTS
  uq_hospital_bookmarks_user_hospital
  ON hospital_bookmarks(user_id, hospital_id);
```

대상: post_likes / hospital_bookmarks

마이그레이션 위치: supabase/migrations/

실제 데이터 상태와 마이그레이션 적용은 이번 발표자료 편집의 실행 범위에 포함하지 않았습니다.